

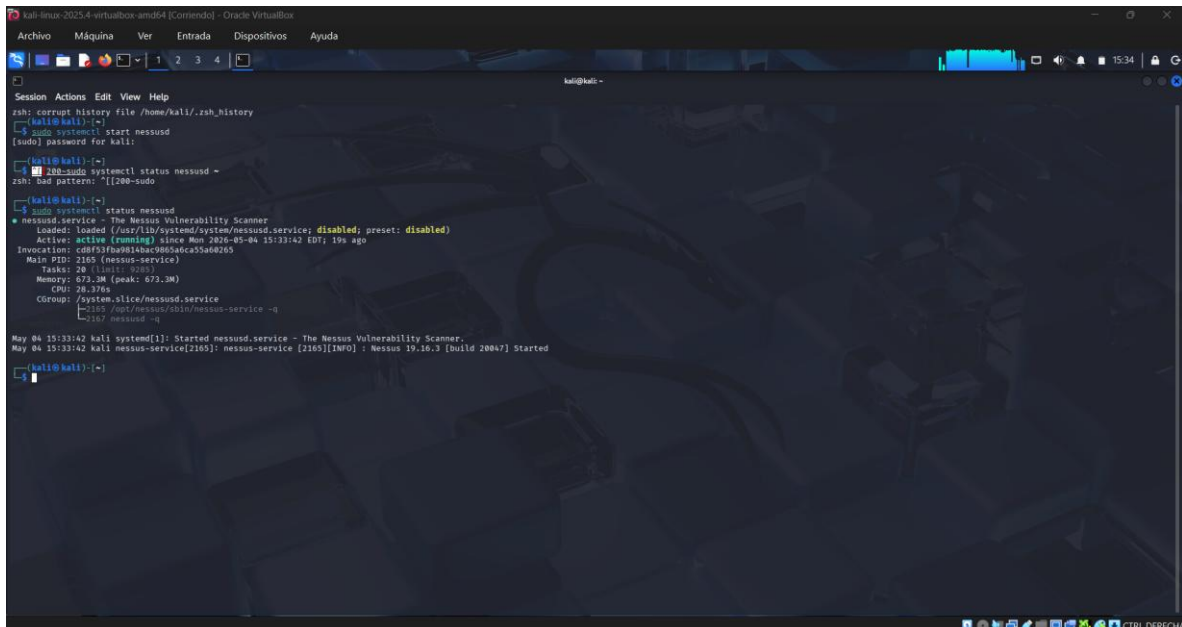
Pruebas a la página oficial de Colombia Comparte Con Nessus

Ahora procederemos a utilizar Nessus, una de las herramientas de escaneo de vulnerabilidades más robustas y extendidas en la industria de la seguridad informática. Mientras que las herramientas anteriores se centran en la lógica web (como el manejo de formularios y sesiones), Nessus realiza un análisis profundo de la infraestructura y superficie de ataque externa del servidor que aloja a Colombia Comparte.

1. Activación del servicio Nessus en la terminal

Para iniciar el análisis de infraestructura, primero debemos activar el demonio del escáner en nuestro entorno de Kali Linux. Como se observa en la imagen, ejecutamos los siguientes comandos técnicos en la terminal:

- **Inicio del servicio:** Utilizamos **sudo systemctl start nessusd** para levantar el motor del escáner.
- **Verificación de estado:** Ejecutamos **sudo systemctl status nessusd** para confirmar que el servicio esté active (running).



```
kali@kali:~$ sudo systemctl start nessusd
[sudo] password for kali:
[kali@kali:~]$ sudo systemctl status nessusd
zsh: Bad pattern: "[[200-sudo
[kali@kali:~]$ sudo systemctl status nessusd
● nessus.service - The Nessus Vulnerability Scanner
   Loaded: loaded (/usr/lib/systemd/system/nessus.service; disabled; preset: disabled)
   Active: active (running) since Mon 2020-05-04 15:33:42 EDT; 19s ago
     Invocation: c08f53fba9814bac9805a6ca5a480205
    Main PID: 2185 (nessus-service)
      Tasks: 28 (limit: 250)
        CPU: 28.39s
       Memory: 673.3M (peak: 673.3M)
         CGroup: /system.slice/nessus.service
                └─2185 /opt/nessus/sbin/nessus-service -q
                  2187 /nessus-q

May 04 15:33:42 kali systemd[1]: Started nessusd.service - The Nessus Vulnerability Scanner.
May 04 15:33:42 kali nessus-service[2185]: nessus-service [2185][1WFO] : nessus 19.10.3 [build 20047] Started
[kali@kali:~]$
```

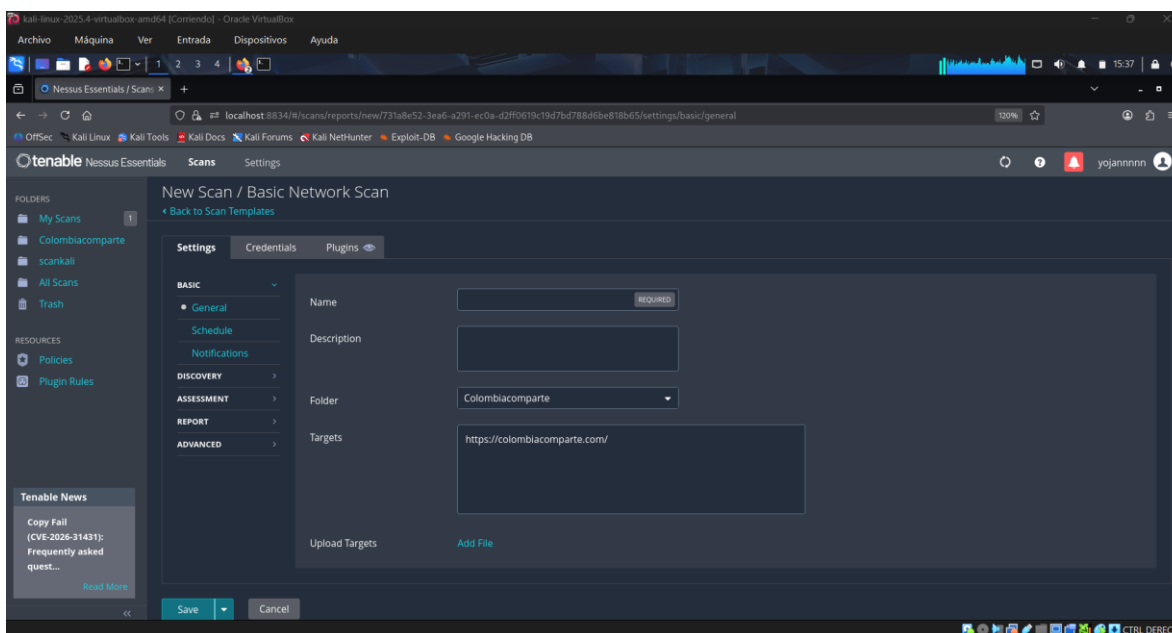
2. Configuración del Proyecto y Definición del Objetivo (Scan Policy)

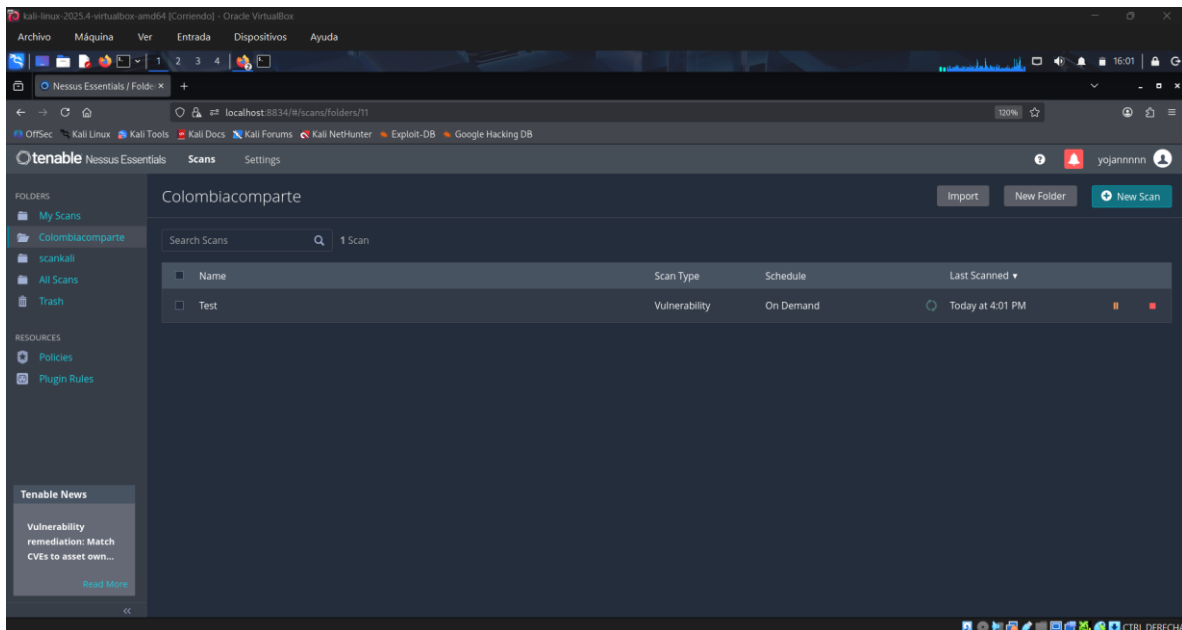
Tras acceder a la interfaz web de **Nessus Essentials** (generalmente en <https://localhost:8834/>), procedemos a organizar el entorno de trabajo y configurar

los parámetros del escaneo. Como se observa en la imagen, realizamos las siguientes acciones técnicas:

- **Gestión de Directorios:** En el panel lateral izquierdo, se ha creado un folder específico denominado "**Colombiacomparte**"
- **Selección de Plantilla:** Se ha seleccionado la opción de **Basic Network Scan**, una política equilibrada diseñada para identificar vulnerabilidades comunes sin afectar la disponibilidad del sitio.

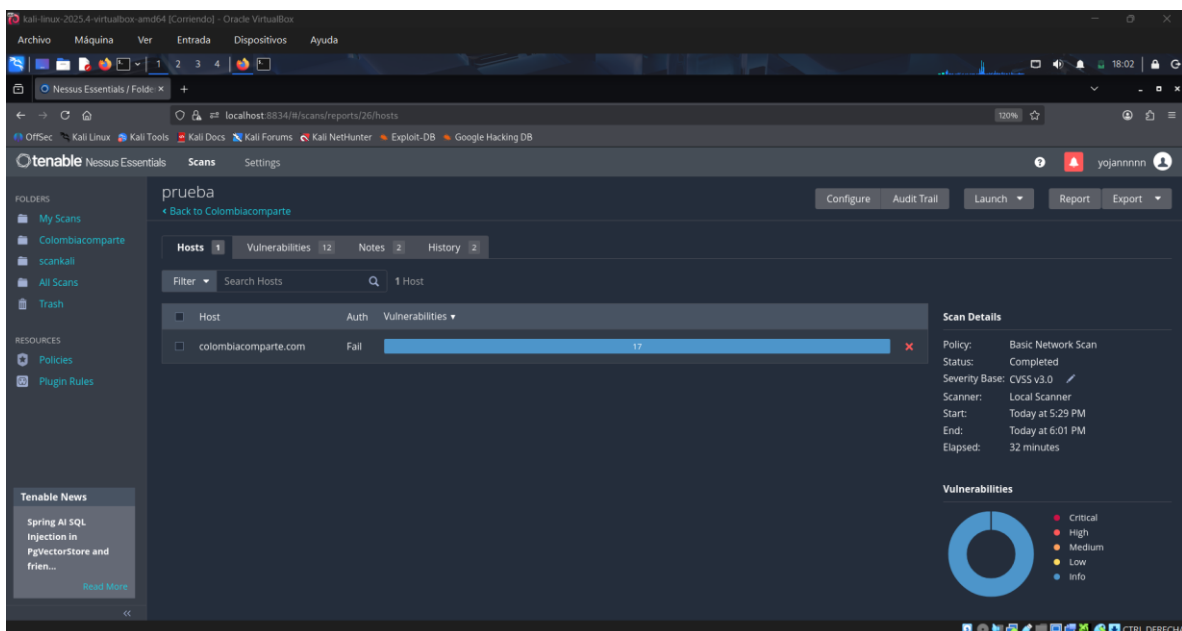
Hay que omitir el protocolo https:// en la configuración del objetivo; de lo contrario, el escáner podría arrojar errores de sintaxis o fallar al intentar identificar los servicios y puertos abiertos en la infraestructura del servidor de **Colombia Comparte**.





3. Ejecución del Escaneo de Vulnerabilidades

Una vez configurado correctamente el objetivo y la política de red, procedemos a iniciar el análisis técnico.

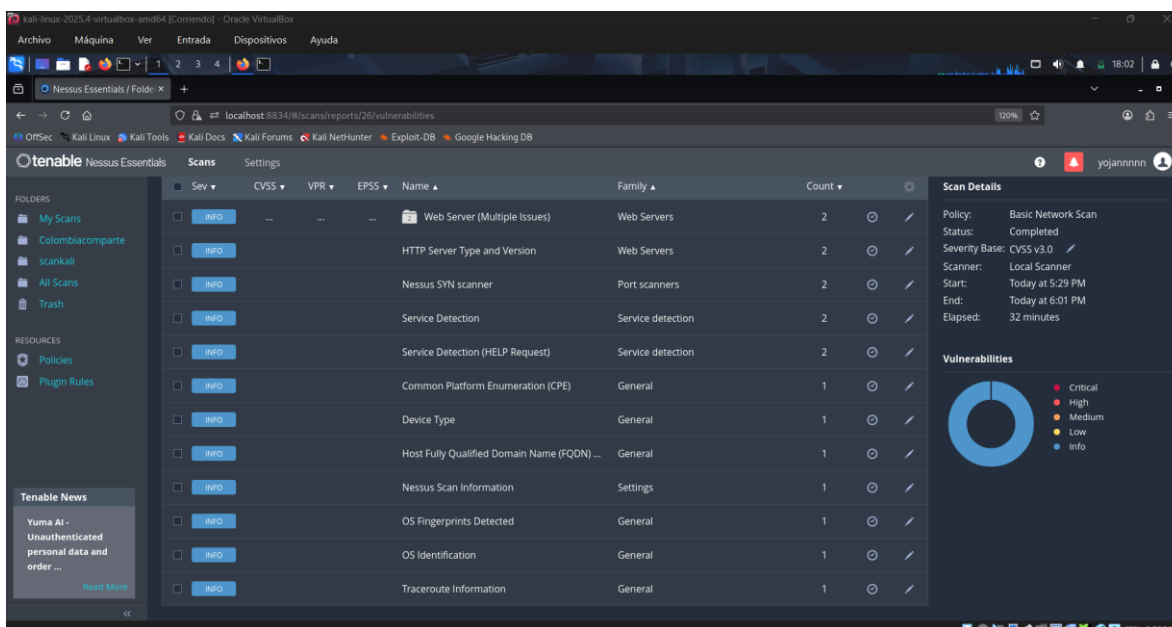


4. Análisis de Hallazgos en la Pestaña de Vulnerabilidades

Tras completar el escaneo, nos situamos en la pestaña de **Vulnerabilities** para evaluar los resultados obtenidos.

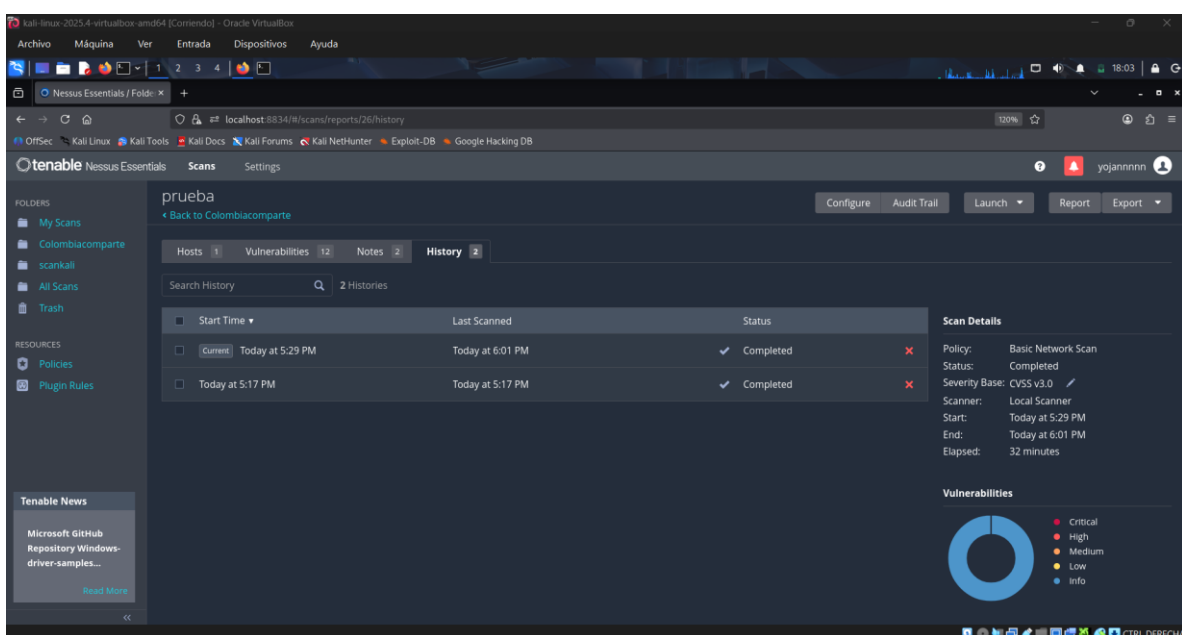
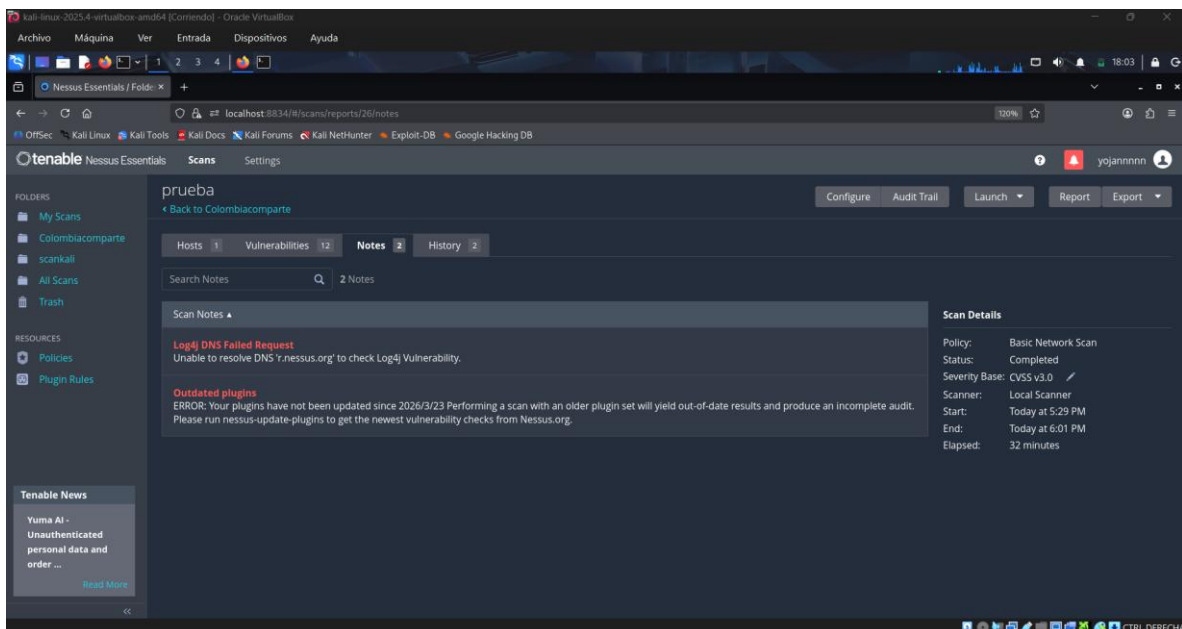
A continuación, se describen los elementos técnicos más relevantes identificados en esta fase de reconocimiento:

- **Web Server (Multiple Issues):** Indica la detección de diversas configuraciones en el servidor web que, aunque no son críticas de forma aislada, requieren revisión para endurecer la postura de seguridad.
- **HTTP Server Type and Version:** El escáner ha logrado identificar la tecnología y la versión del servidor web. Esta información es valiosa para un auditor (o un atacante), ya que permite buscar vulnerabilidades específicas (CVE) para esa versión exacta.
- **Service Detection & OS Fingerprints:** Nessus ha realizado un "huellado" exitoso, determinando los servicios activos y el sistema operativo que corre en el host. La detección de servicios mediante **SYN scanner** y solicitudes **HELP** confirma qué puertos están abiertos y respondiendo a estímulos externos.
- **Common Platform Enumeration (CPE) & FQDN:** Se ha identificado el nombre de dominio completamente calificado y se han estandarizado los componentes de software detectados, lo que facilita el inventario de activos tecnológicos de **Colombia Comparte**.



5. Revisión de Observaciones Técnicas (Scan Notes)

Al finalizar el escaneo, es vital revisar la pestaña de **Notes** para identificar posibles limitaciones o advertencias durante el proceso de auditoría.



Se presentan las siguientes conclusiones técnicas basadas en los resultados obtenidos:

- **Estado de la Superficie de Ataque:** El análisis identificó un total de 17 hallazgos iniciales. Aunque la mayoría de los resultados se clasifican en el nivel **INFO** (Informativo), la visibilidad de puertos y servicios expuestos

confirma una superficie de ataque que permite el reconocimiento externo detallado.

- **Exposición de Información Sensible:** Se detectaron múltiples issues relacionados con el servidor web, incluyendo la identificación precisa del tipo y versión del servidor HTTP. Esta fuga de información técnica facilita la búsqueda de vulnerabilidades específicas (CVE) que podrían ser explotadas en versiones desactualizadas.
- **Dictamen de Infraestructura:** Si bien no se detectaron vulnerabilidades críticas inmediatas en los servicios de red básicos, la infraestructura presenta una "higiene digital" mejorable. Se recomienda ocultar las cabeceras de versión del servidor y realizar una actualización completa de plugins antes de ejecutar un escaneo de validación final.